

WebVulnPro Security Assessment Report

Generated: 2026-07-17 21:18:17

Executive Summary

Targets Scanned	1
Total Vulnerabilities	11
Critical	0
High	1
Medium	8
Low	2
Informational	0
Overall Risk Score	85/100

Technologies Detected

■ Framework

Technology	Version	Confidence
FastAPI	-	20%

■ UI Framework

Technology	Version	Confidence
Tailwind CSS	-	20%

■ Programming Language

Technology	Version	Confidence
Python	-	10%

■ ■ Web Server

Technology	Version	Confidence
Apache	2.4.7	35%

■ Operating System

Technology	Version	Confidence
Ubuntu	-	35%

■ Analytics

Technology	Version	Confidence
Google Analytics	-	45%
Segment	-	25%

Target: <http://scanme.nmap.org/>

Severity	Title	CVSS	Category
HIGH	Missing Content Security Policy (CSP)	7.1	HTTP Headers
MEDIUM	Missing X-Frame-Options Header	5.4	HTTP Headers
MEDIUM	Missing X-Content-Type-Options Header	5.3	HTTP Headers
MEDIUM	Missing Referrer-Policy Header	4.3	HTTP Headers
MEDIUM	Missing Permissions-Policy Header	4.3	HTTP Headers
MEDIUM	Forms Missing CSRF Protection	5.3	CSRF
MEDIUM	Directory Listing Enabled: /images/	5.3	Misconfiguration
MEDIUM	Potential DOM-based XSS in nst.js?v=2	6.1	Cross-Site Scripting
MEDIUM	Potential HTTP Request Smuggling Vector	5.3	HTTP Protocol
LOW	Missing or Weak Cache-Control Header	3.7	HTTP Headers
LOW	Server Version Disclosure	2.6	Information Disclosure

Detailed Findings

[HIGH] Missing Content Security Policy (CSP)

CVSS Score: 7.1 | **Category:** HTTP Headers | **CWE:** CWE-1021

Description: No Content-Security-Policy header found. This makes the application vulnerable to XSS and data injection attacks.

Remediation: Implement a strict CSP. Start with: Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'

Evidence: Header 'content-security-policy' not found in response

[MEDIUM] Missing X-Frame-Options Header

CVSS Score: 5.4 | **Category:** HTTP Headers | **CWE:** CWE-1021

Description: X-Frame-Options header is missing. The site may be vulnerable to clickjacking attacks.

Remediation: Add 'X-Frame-Options: DENY' or 'X-Frame-Options: SAMEORIGIN' header.

Evidence: Header 'x-frame-options' not found in response

[MEDIUM] Missing X-Content-Type-Options Header

CVSS Score: 5.3 | **Category:** HTTP Headers | **CWE:** CWE-693

Description: X-Content-Type-Options header is missing. Browsers may MIME-sniff responses, potentially executing malicious content.

Remediation: Add 'X-Content-Type-Options: nosniff' header.

Evidence: Header 'x-content-type-options' not found in response

[MEDIUM] Missing Referrer-Policy Header

CVSS Score: 4.3 | **Category:** HTTP Headers | **CWE:** CWE-200

Description: Referrer-Policy header is missing. Sensitive information may leak via the Referer header.

Remediation: Add 'Referrer-Policy: strict-origin-when-cross-origin' or 'no-referrer' header.

Evidence: Header 'referrer-policy' not found in response

[MEDIUM] Missing Permissions-Policy Header

CVSS Score: 4.3 | **Category:** HTTP Headers | **CWE:** CWE-16

Description: Permissions-Policy (formerly Feature-Policy) header is missing. Browser features are not restricted.

Remediation: Add Permissions-Policy header to restrict features: Permissions-Policy: geolocation=(), camera=(), microphone=()

Evidence: Header 'permissions-policy' not found in response

[MEDIUM] Forms Missing CSRF Protection

CVSS Score: 5.3 | **Category:** CSRF | **CWE:** CWE-352

Description: Found 2 form(s) without visible CSRF token protection.

Remediation: Implement CSRF tokens in all state-changing forms.

Evidence: 2 forms without csrf tokens detected

[MEDIUM] Directory Listing Enabled: /images/

CVSS Score: 5.3 | **Category:** Misconfiguration | **CWE:** CWE-548

Description: Directory listing is enabled for '/images/'.

Remediation: Disable directory listing in web server configuration.

Evidence: URL: <http://scanme.nmap.org/images/>

[MEDIUM] Potential DOM-based XSS in nst.js?v=2

CVSS Score: 6.1 | **Category:** Cross-Site Scripting | **CWE:** CWE-79

Description: JavaScript contains both DOM XSS sources and sinks that could be exploitable.

Remediation: Review and sanitize all DOM manipulation operations. Use `textContent` instead of `innerHTML` where possible.

Evidence: File: <http://scanme.nmap.org/shared/js/nst.js?v=2> Sinks: `location.hrefs*=` Sources: `location.href`

[MEDIUM] Potential HTTP Request Smuggling Vector

CVSS Score: 5.3 | **Category:** HTTP Protocol | **CWE:** CWE-444

Description: The server accepts requests with conflicting Content-Length and Transfer-Encoding headers, which may indicate vulnerability to HTTP request smuggling.

Remediation: Configure the server to reject requests with conflicting Content-Length and Transfer-Encoding headers. Ensure proper HTTP parsing at all layers.

Evidence: Server accepted request with both Content-Length and Transfer-Encoding headers. Response status: 200

[LOW] Missing or Weak Cache-Control Header

CVSS Score: 3.7 | **Category:** HTTP Headers | **CWE:** CWE-525

Description: Cache-Control header is missing or misconfigured. Sensitive data may be cached by browsers or proxies.

Remediation: For sensitive pages, add 'Cache-Control: no-store, no-cache, must-revalidate, private'

Evidence: Header 'cache-control' not found in response

[LOW] Server Version Disclosure

CVSS Score: 2.6 | **Category:** Information Disclosure | **CWE:** CWE-200

Description: The Server header reveals web server software and version information.

Remediation: Remove or obfuscate the Server header to hide implementation details.

Evidence: server: Apache/2.4.7 (Ubuntu)